

PraisonAI CLI automatically resolves @url mentions in prompt text and can read loopback URLs into model context

Report Type: Weekly · Generated: May 31, 2026 16:17 UTC · Coverage: May 29 – May 31, 2026

1	0	0	1
Total Advisories	Critical	High	Medium

Executive Summary

Summary PraisonAI's direct-prompt CLI automatically expands `@url:` mentions in raw prompt text before agent execution begins. If a prompt contains `@url:`, the CLI calls `MentionsParser.process(...)`. The `@url:` handler then performs a direct `urllib.request.urlopen()` request to the attacker-controlled URL and returns the response body. That response body is prepended to the final model prompt context. There is no loopback/private-address restriction, no metadata-service restriction, and no approval gate before the fetch. As a result, attacker-influenced prompt text can cause the operator's machine to fetch localhost-only HTTP resources and inject the response into model context. Example: `text @url:http://localhost:8766/summarize this` This causes PraisonAI to make an HTTP request to the local machine and prepend the fetched response body to the prompt that the model receives. This is a narrow local SSRF / local content disclosure issue in aut

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
PraisonAI CLI automatically resolves @url mentions in prompt text and ca	MEDPROM	5.5	—	### Summary PraisonAI's direct-prompt CLI automatically expands `@url:` n

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Monitor PraisonAI CLI automatically resolves @url mentions in prompt text and can read loopback URLs into model context for escalation.
2. Apply patches in next maintenance window.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--6acbcc5f6402097e26a05beb
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T16:17:22.939391+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.